CATO NETWORKS

CTRL BY CATO NETWORKS



Cato CTRL™ Threat Actor Profile:

ShinyHunters

The Brand that Outlasts the Takedowns

Author: Vitaly Simonovich

TL;DR

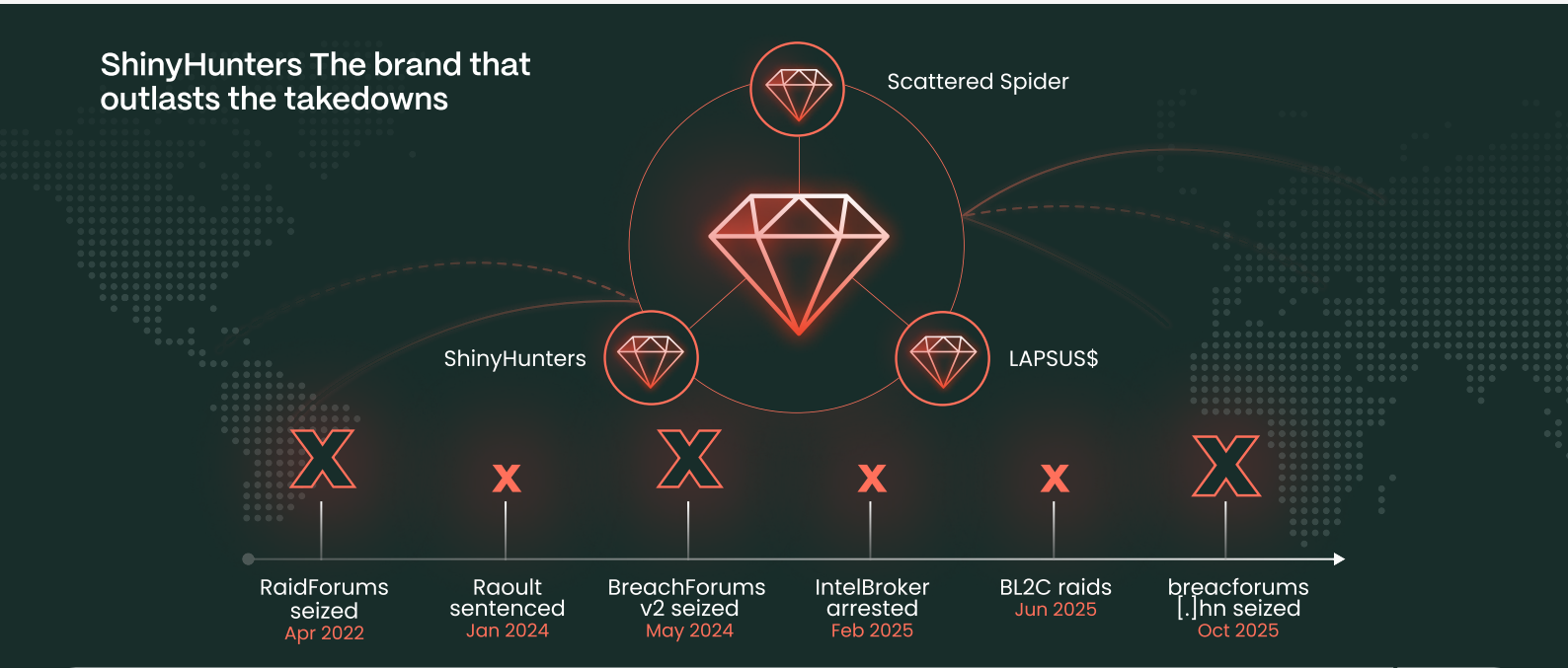
If your enterprise runs Salesforce, Salesloft Drift, Gainsight, or any third-party SaaS integration, the 2025-2026 ShinyHunters playbook walks past MFA without trying to break it: A vishing call talks your help desk into approving a malicious OAuth-connected app, then bulk API queries do the rest. The reason it keeps working is that ShinyHunters isn't a group anymore; it's a brand that has outlasted RaidForums, two BreachForums seizures, one founder conviction, and five admin arrests across three separate operations. Removing the brand isn't on the table; removing the conditions that make its playbook profitable in your environment is.

Executive Summary

If your detection model still assumes that a strong perimeter and MFA are enough, you're in for some bad news. The ShinyHunters playbook running today already walks right through it. Cato CTRL has tracked the brand across six years of operations, three forum seizures, and an international law-enforcement campaign that should have ended it three times over. It hasn't. April 2026 alone saw five fresh BreachForums listings in seven days, including live admin access bundles for Vercel and Compass. Telus is still investigating ShinyHunters' claim of 700 TB exfiltrated.

The rest of this profile works through the brand's origins, the August 2025 SLH merger with Scattered Spider and LAPSUS$, the 2025 pivot to identity-driven business logic abuse (UNC6040 vishing, UNC6395 OAuth supply chain), the law-enforcement timeline that proves the brand's resilience, and what changes Monday morning for your OAuth governance.

Cato customers are protected against ShinyHunters TTPs through Cato Dynamic Prevention (the auto-adaptive threat prevention engine that correlates months of behavior across Cato's inline sensors and out-of-band engines to block multi-stage attacks without SOC intervention), plus IPS, OAuth visibility, DLP, and Cato MDR threat hunting on the Cato SASE Cloud Platform. Detail in the Cato Protections section below.



Phase II: The BreachForums Era (2022–2025)

ShinyHunters takes its name from the *Pokémon* community term for players hunting rare "shiny" variants. A fitting metaphor for a group that built its early reputation on chasing rare, high-value databases.
The group emerged publicly in early 2020. Within a two-week stretch in May 2020, ShinyHunters listed more than 200 million stolen records across multiple dark-web forums. The initial portfolio was a consumer-platform PII at scale:

- **Mathway (2020):** 25 million records (emails, hashed passwords)
- **Tokopedia (2020):** 91 million records (PII, dates of birth, hashed passwords)
- **Wattpad (2020):** ~270 million records (~268M unique email addresses)
- **Animal Jam (2020):** 46 million records
- **Microsoft / GitHub (2020):** ~500 GB of code samples and test projects

Microsoft assessed the GitHub data as "mostly code samples, test projects, an eBook, and other generic items" rather than proprietary IP. The volume was real; the impact was less than ShinyHunters' marketing implied. That gap between claim and reality has been a recurring feature of the brand.
A June 2021 indictment in the Western District of Washington named three French nationals as the original ShinyHunters cell:

- **Sébastien Raoult**
  ("Sezyo Kaizen"). Phishing-kit and fake login portal developer
- **Gabriel Kimiaie-Asadi Bildstein**
  ("Kuroi'SH", member of GnosticPlayers). Intrusion specialist
- **Abdel-Hakim El Ahmadi**
  ("Zac" / "Jordan Keso"). Co-conspirator and network facilitator

Only Raoult has been convicted. Raoult was 21 when he was arrested at Rabat-Salé Airport in May 2022 while attempting to board a flight to France. His day-to-day work on the cell was technical: he built the fake login portals (Microsoft, GitHub, Atlassian, AWS) the group used to harvest enterprise credentials, and operated the phishing infrastructure that fed those credentials back to the operation. Morocco extradited him to the U.S. in January 2023. On January 9, 2024, a Seattle district court sentenced him to three years in prison and over $5 million in restitution. Bildstein and El Ahmadi are believed to remain at large in France.

Phase II: The BreachForums Era (2022–2025)

Public reporting often credits ShinyHunters with founding BreachForums. That's wrong. BreachForums was launched on **March 16, 2022** by **Conor Brian Fitzpatrick** ("pompompurin"), then a 19-year-old from Peekskill, New York, as a successor to RaidForums. He turned 20 by the time the FBI arrested him at his parents' house in Peekskill in March 2023. Fitzpatrick administered the entire forum (account creation, dispute resolution, banning, escrow services for stolen-data sales) under the Sanrio-character handle "pompompurin", the same handle he used on legitimate gaming forums he frequented. RaidForums itself had been hit weeks earlier. Alleged founder **Diogo Santos Coelho** ("Omnipotent") was arrested in the U.K. on **January 31, 2022**, and the seizure was publicly announced on **April 12, 2022** as part of Operation TOURNIQUET.

ShinyHunters took over **administration** of BreachForums in **June 2023**, after Fitzpatrick's March 2023 arrest. The group partnered with the admin known as **Baphomet** to relaunch BreachForums v2.

This is where the strategic posture shifted. ShinyHunters stopped being users of stolen-data marketplaces and started running them. Owning the marketplace meant owning the rules: data auctions, member dispute resolution, and visibility into who was buying what. The forum has been seized twice since:

- **May 15, 2024:** FBI takes down BreachForums v2. Baphomet's reported arrest is widely cited but never formally announced by DOJ.
- **April 28, 2025:** Administrators publish a PGP-signed shutdown notice citing a MyBB zero-day vulnerability as the reason. Some reporting attributes the outage instead to a Dark Storm Team DDoS, others to law enforcement infiltration. The cause remains contested.

After each seizure, the brand re-emerged within days on a new top-level domain. As of April 2026, listings appear on `breachforums[.]rs`. The persistence isn't technical resilience. It's organizational. Removing one admin doesn't kill the brand because the brand is the asset.

Phase III: Identity-Driven Business Logic Abuse (2024-Present)

By mid-2024, ShinyHunters had stopped looking like a database-harvesting crew. The 2025 campaigns are different. Patient. Identity-aware. Surgical.

Cluster ID	Year	Target surface	Technique	Attributed activity
UNC5537	**2024**	**Snowflake**	Replay infostealer-harvested credentials against accounts without MFA	The Snowflake wave (AT&T, Ticketmaster, Santander, LendingTree, Advance Auto Parts)
UNC6040	**2025**	**Salesforce**	Help-desk vishing then victim authorizes a malicious OAuth-connected app (modified Data Loader)	Kering / Gucci, Balenciaga, McQueen, Brioni breach
UNC6395	**2025 (Aug)**	**Salesforce via Salesloft Drift**	Stolen integration OAuth tokens (root cause: Salesloft GitHub breach, Mar to Jun 2025)	Multiple Salesforce customers
UNC6661	**2026 (Jan)**	**SSO + MFA**	Vishing then victim-branded credential-harvesting site then attacker registers own MFA device	Multiple Salesforce customers
UNC6671	**2026 (Jan)**	**SSO + MFA**	Parallel vishing campaign with the same playbook	GTIG tracks separately to allow for impersonation
UNC6240	**2026**	**Extortion / monetization**	Tox negotiation accounts, ShinyHunters-branded extortion emails, Limewire sample hosting	= ShinyHunters per GTIG; handles post-intrusion ransom for UNC6661

The rest of this section walks through what each cluster did. The 2026 wave is covered together as the cluster expansion (see UNC6661/UNC6671/UNC6240 below).

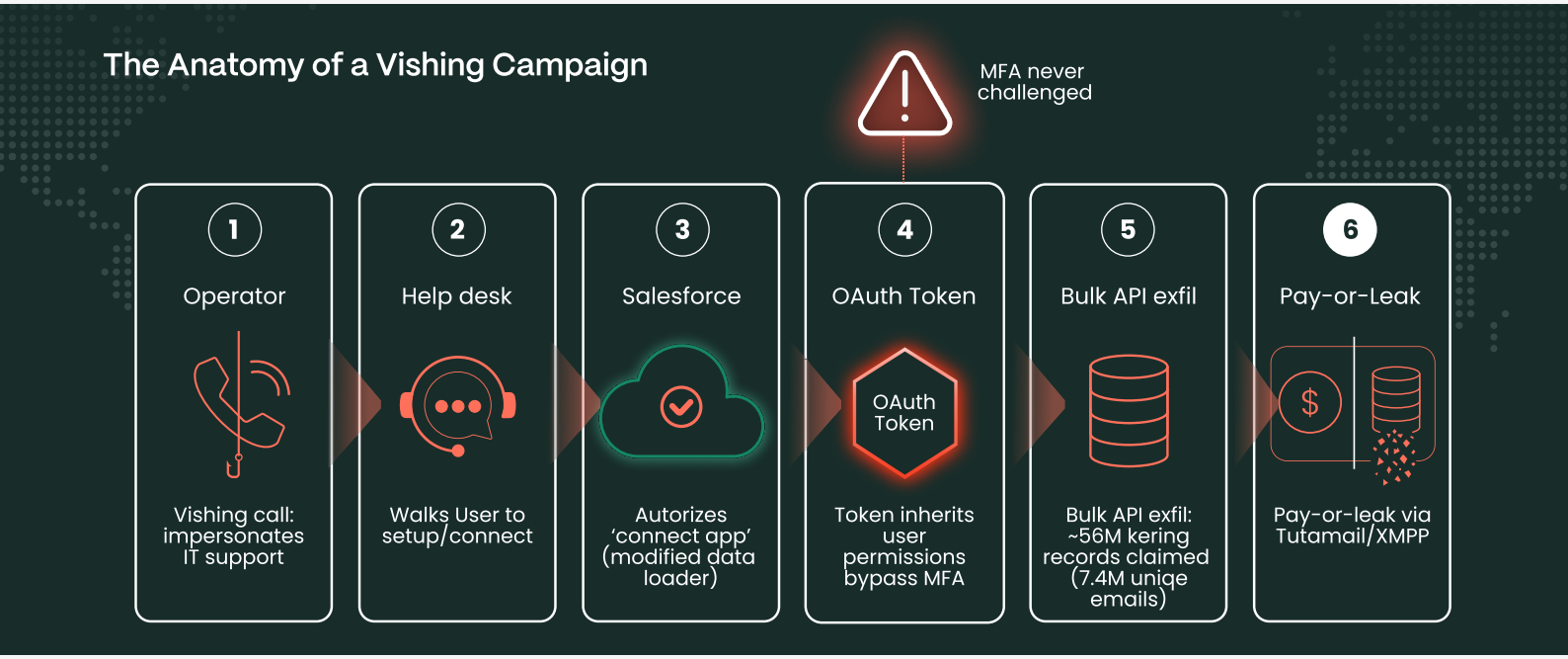
The Snowflake Wave (UNC5537, 2024)

Mandiant tracked the cluster as UNC5537. The technique was unglamorous and devastating: replay infostealer-harvested credentials against Snowflake instances that hadn't enforced MFA. Mandiant's published analysis named six infostealer variants in the credential supply chain: **VIDAR, RISEPRO, REDLINE, RACOON STEALER, LUMMA, and METASTEALER**. Mandiant's analysis also found that **79.7%** of accounts used in the campaign had prior credential exposure. The earliest infostealer infection date observed dated back to **November 2020**.

Confirmed and reported victims included AT&T, Ticketmaster, Santander, LendingTree, and Advance Auto Parts. AT&T reportedly paid a **$370,000** ransom to suppress the release of call-detail records. The only payment publicly documented to date.

The group's custom Snowflake reconnaissance tool, **FROSTBITE** (also called "rapeflake"), was observed by Mandiant in both .NET and Java versions. It enumerated users, roles, IPs, and session IDs. Native Snowflake SQL, `CREATE TEMPORARY STAGE`, `COPY INTO`, `GET`, staged the exfiltration. Data landed on MEGA and on VPS providers including **ALEXHOST SRL** (Moldova).

The Salesforce Vishing Campaign (UNC6040, 2025)



Mandiant tracks the 2025 Salesforce campaign as UNC6040. The FBI issued an IC3 advisory (CSA-2025-0912) covering both UNC6040 and the related UNC6395 cluster.

The attack chain bypasses MFA without bypassing it:

1. The operator phones the help desk, impersonating internal IT support
2. Walks the employee through "connectivity troubleshooting" that ends at Salesforce's `/setup/connect` URL
3. Employee authorizes a malicious "connected app". Typically a modified Salesforce Data Loader
4. OAuth access token is generated, inheriting the employee's permissions
5. Bulk API queries pull tens of millions of records from the cloud environment

In **April 2025**, this technique was used against Gucci, Balenciaga, Brioni, and Alexander McQueen. All owned by the Kering luxury conglomerate. The breach wasn't discovered until **June 2025**. DataBreaches.net broke the story on **September 11, 2025**; Kering issued its own public confirmation a few days later, around **September 15, 2025**.

ShinyHunters claimed roughly **43 million records from Gucci alone** plus close to 13 million combined from Balenciaga, Brioni, and Alexander McQueen, with **7.4 million unique customer email addresses** as the deduplicated identity count, alongside names, addresses, phone numbers, and total spend totals. Kering confirmed the breach occurred but did not confirm record counts. ShinyHunters told DataBreaches that Balenciaga had agreed to a €500,000 ransom payment, only to reneg on it; Kering has publicly denied that any ransom negotiation took place.

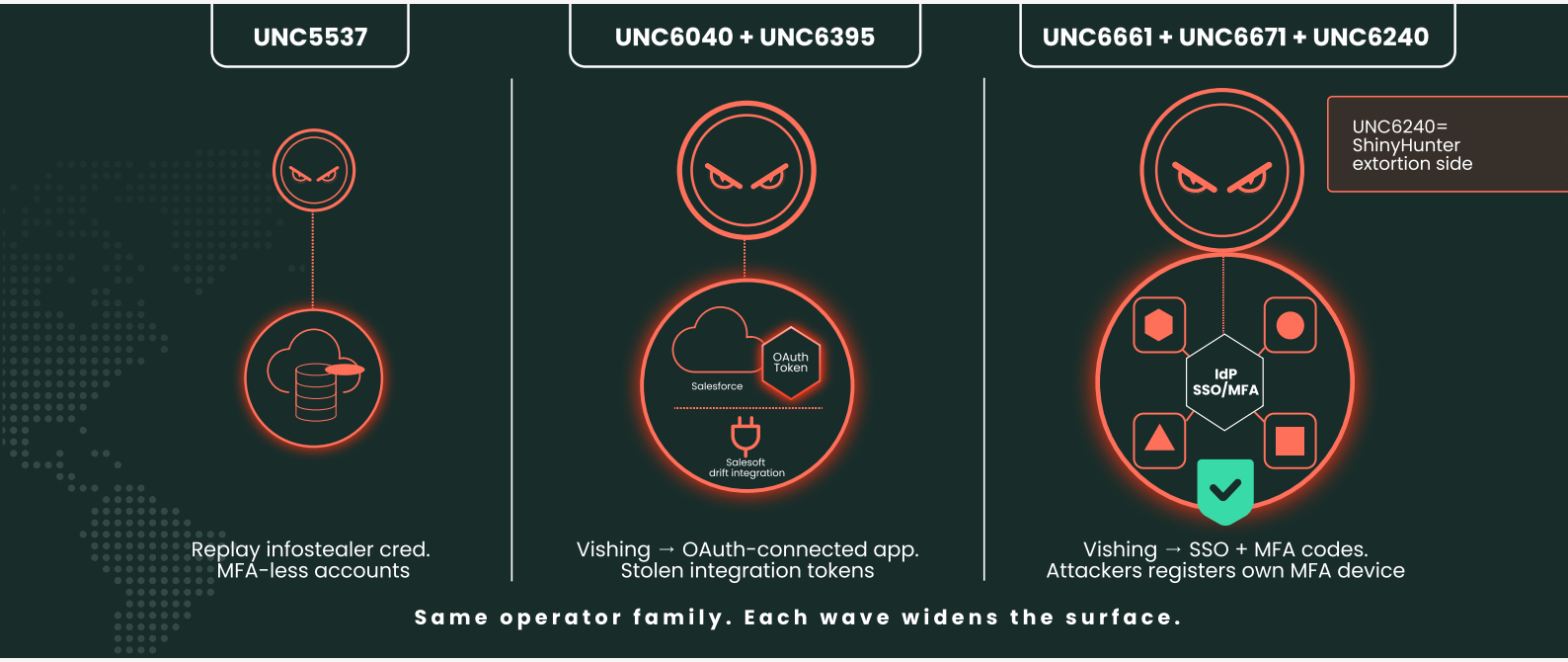
Third-Party OAuth Supply Chain (UNC6395, August 2025)

UNC6395 is a parallel cluster that didn't need to phone anyone. The group exploited compromised OAuth tokens from the Salesloft Drift chatbot integration with Salesforce. Mandiant traced the token compromise back to a breach of Salesloft's GitHub account between March and June 2025.
A stolen OAuth token from a trusted SaaS-to-SaaS integration is the cleanest possible foothold. There's no malware to detect, no credential challenge to fail, and no perimeter to traverse. The integration was already trusted.

Two-Vector Reality

The two campaigns running simultaneously matter strategically. Most enterprises that hardened their help desk against UNC6040-style vishing were still exposed via UNC6395-style integration token theft. A defender focused on phishing-resistant MFA on user accounts isn't necessarily watching for new connected-app authorizations or for compromised third-party SaaS integrations.

2026 Cluster Expansion: UNC6661, UNC6671, UNC6240



In January 2026, Google Threat Intelligence Group (GTIG, formerly Mandiant) expanded the cluster taxonomy beyond UNC6040/UNC6395 to track the next tactical evolution. UNC6661 ran early-to-mid-January 2026 vishing operations impersonating IT staff, claiming the company was "updating MFA settings," and directing employees to victim-branded credential-harvesting sites that captured SSO credentials and MFA codes. The operator then registered their own device for MFA on the victim's identity provider, surviving any later password rotation. UNC6671 ran a parallel vishing campaign against different targets using the same playbook over the same window. UNC6240 is the extortion side of the equation: GTIG attributes the post-intrusion ransom activity following UNC6661 intrusions to UNC6240 based on shared Tox negotiation accounts, ShinyHunters-branded extortion emails, and Limewire as the sample-hosting service. A new ShinyHunters-branded data-leak site labeled "SHINYHUNTERS" appeared in late January 2026, listing fresh victims tied to this wave.

The technical shift matters. UNC6040 (2025) was Salesforce-specific and abused the OAuth-connected-app authorization flow. The UNC6661/6671/6240 cluster (2026) targets the broader SSO + MFA layer directly, which means any SaaS the target federates with their identity provider becomes reachable, not just Salesforce. The "phishing-resistant MFA" advice from 2025 still holds; the surface it has to cover just got wider.

The Federated Brand: Scattered LAPSUS$ Hunters (SLH)

In **August 2025**, three of the most recognizable English-speaking cybercrime brands publicly merged.

- **Scattered Spider (UNC3944).** Social engineering and help-desk impersonation
- **LAPSUS$.** Aggressive intrusion, MFA fatigue, insider recruitment
- **ShinyHunters.** Data exfiltration, monetization, marketplace administration

The first verified Telegram channel, scattered lapsu$ hunters, The Com HQ SCATTERED SP1D3R HUNTERS, appeared on **August 8, 2025**. By late 2025, at least 16 Telegram channels were operating under the SLH banner. PGP-signed messages on those channels could be verified against previously known ShinyHunters keys.

The Qantas/Vietnam Airlines leak in October 2025 carried the channel name "SLSH 6.0 part 3 – lapsus$hiny$scatteredwizard" directly in the post. The first time the SLH branding was tied to a high-confidence concrete data dump.

Trustwave SpiderLabs assesses SLH as a **federated brand**, not a centralized organization. That distinction matters. There may be no boss to indict. The collective draws members from "The Com". The loose English-speaking cybercrime ecosystem populated heavily by young actors, often teenagers, sharing playbooks and recruiting through Discord and Telegram.

ShinySp1d3r: The Coming RaaS Pivot

On **November 19, 2025**, BleepingComputer reported on a Ransomware-as-a-Service program in active development under the SLH banner: **ShinySp1d3r.**

Reported technical characteristics, based on early build analysis:

- **Encryption:** ChaCha20 with the symmetric key protected by RSA-2048
- **Targets:** Windows currently; Linux and VMware ESXi versions reportedly close to release
- **Anti-forensics:** Hooks `EtwEventWrite` to suppress Event Tracing for Windows (ETW) telemetry. Blinding Windows Event Viewer indirectly via the API rather than disabling the service
- **Anti-recovery:** Removes Volume Shadow Copies
- **Process termination:** Hard-coded list of services and processes
- **Self-propagation:** Built-in lateral spread methods including `deployViaSCM`, `deployViaWMI`, and `attemptGPODeployment`

ShinySp1d3r should be treated as ransomware still in development rather than a deployed family. No confirmed deployments have been publicly reported. The provenance is also contested: BleepingComputer and most secondary analysts characterize ShinySp1d3r as a custom-built encryptor not based on known families like LockBit, Qilin, or DragonForce, while one SOS Ransomware analysis assesses the early build as a modified version of the leaked Hellcat ransomware source code with AI-assisted edits. Either way, the development signal matters. ShinyHunters has spent six years specifically *avoiding* file encryption. The group's entire monetization model has been built on data theft and extortion. Building a RaaS is a strategic pivot toward affiliate-driven, encryption-capable operations alongside the existing extortion playbook.

Notable Incidents (2024–2026)

The following are the highest-impact incidents in the corpus, drawn from Cato CTRL tracking and public reporting:

2024 (Snowflake wave, UNC5537):

- **AT&T (Telecom):** Snowflake call records; $370K ransom paid (the only publicly documented payment in the wave).
- **Ticketmaster (Entertainment):** Snowflake; 560M records claimed.
- **Santander (Banking):** Initial Snowflake breach, multi-region.
- **Cylance / BlackBerry (Cybersecurity, Jun 2024):** 34M records (2015–2018 marketing data) listed by handle "Sp1d3r" for $750K. BlackBerry denied current customer data was compromised.

2025 (pivot to identity-driven business logic abuse, UNC6040 / UNC6395):

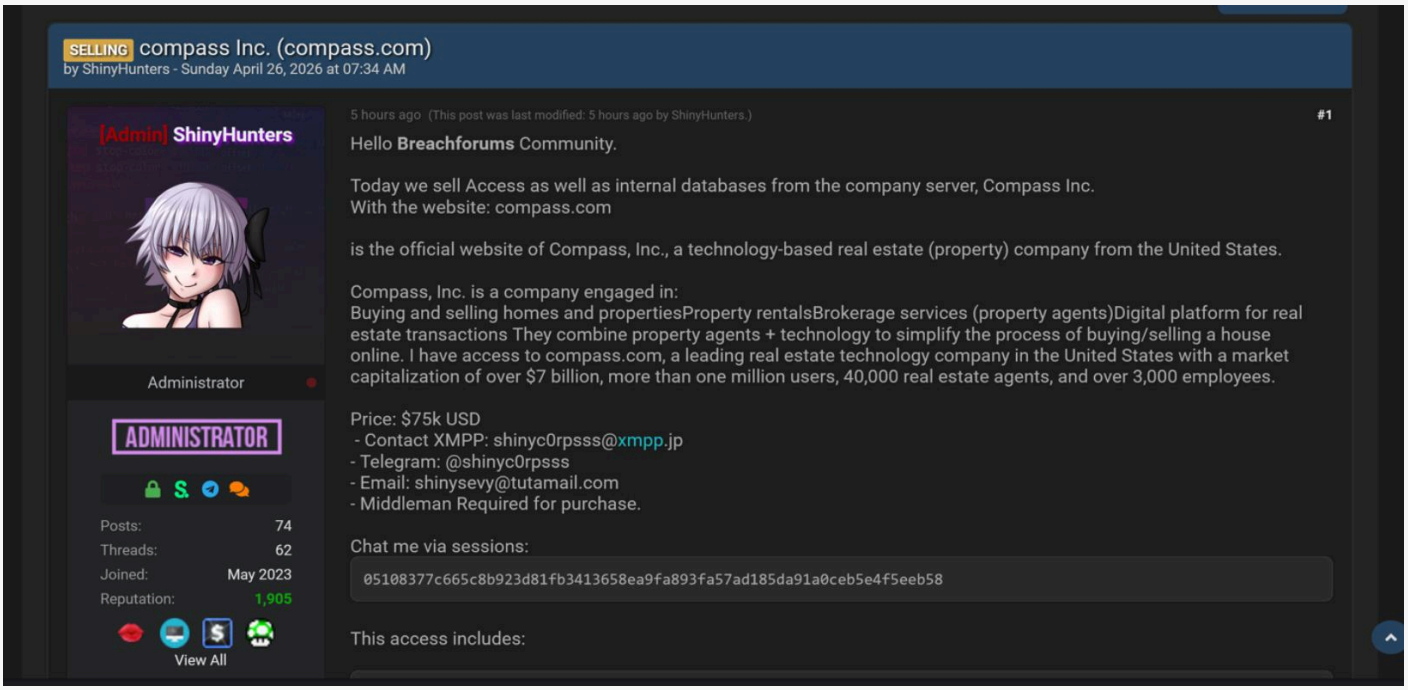
- **Kering (Gucci, Balenciaga, McQueen, Brioni**; Luxury retail): Breach in April 2025, discovered June 2025; DataBreaches.net broke the story on September 11, 2025, with Kering's own public confirmation following around September 15, 2025. ShinyHunters claimed ~43M Gucci records + ~13M others (7.4M unique emails deduplicated) via Salesforce vishing. Kering confirmed the breach, denied any ransom negotiation, did not confirm record counts.
- **Salesloft Drift OAuth abuse (Multiple Salesforce customers, Aug 2025):** UNC6395 cluster.
- **Credit Institute of Vietnam (Financial / Government, Sep 2025):** 160M+ records claimed.
- **Qantas Airways (Aviation, Oct 2025):** 5.7M unique customers affected per Qantas; ~5M-record dataset leaked publicly after ransom refusal.
- **Vietnam Airlines (Aviation, Oct 2025):** 23M records / 63.62 GB dataset claimed; Have I Been Pwned verified 7.3M unique email addresses.
- **FBI / DOJ contractors (Government, Oct 2025, claimed):** 542 federal-agency clients listed.

- **Millicom / Tigo (Telecom, listed Nov 13, 2025):**
  - **What was listed:** 380M+ records, 1.3 TB. ShinyHunters told DataBreaches.net the data came from a mid-September 2025 intrusion that exploited CVE-2024-2577 to steal AWS credentials and pull S3 database backups.
  - **Why the CVE attribution doesn't hold up:** NVD lists CVE-2024-2577 as an IDOR in SourceCodester Employee Task Management System v1.0, an unrelated open-source PHP web app. The CVE doesn't match the described attack vector and shouldn't be used as a defensive signal.
  - **The more likely provenance:** The dataset most plausibly traces to the January 4, 2024 ransomware incident at Tigo Business Paraguay (publicly attributed at the time to Black Hunt, which Tigo Paraguay disputed), where 330+ servers were encrypted and backups were compromised. Botcrawl's contemporaneous analysis assesses the November 2025 listing as the long-tail extortion phase of that earlier breach. Millicom had not publicly acknowledged the breach as of November 18, 2025.
- **French Ministry of Interior (Government, Dec 2025, claimed by "Indra"):** 16.4M records (TAJ, FPR, DGFIP, CNAV).

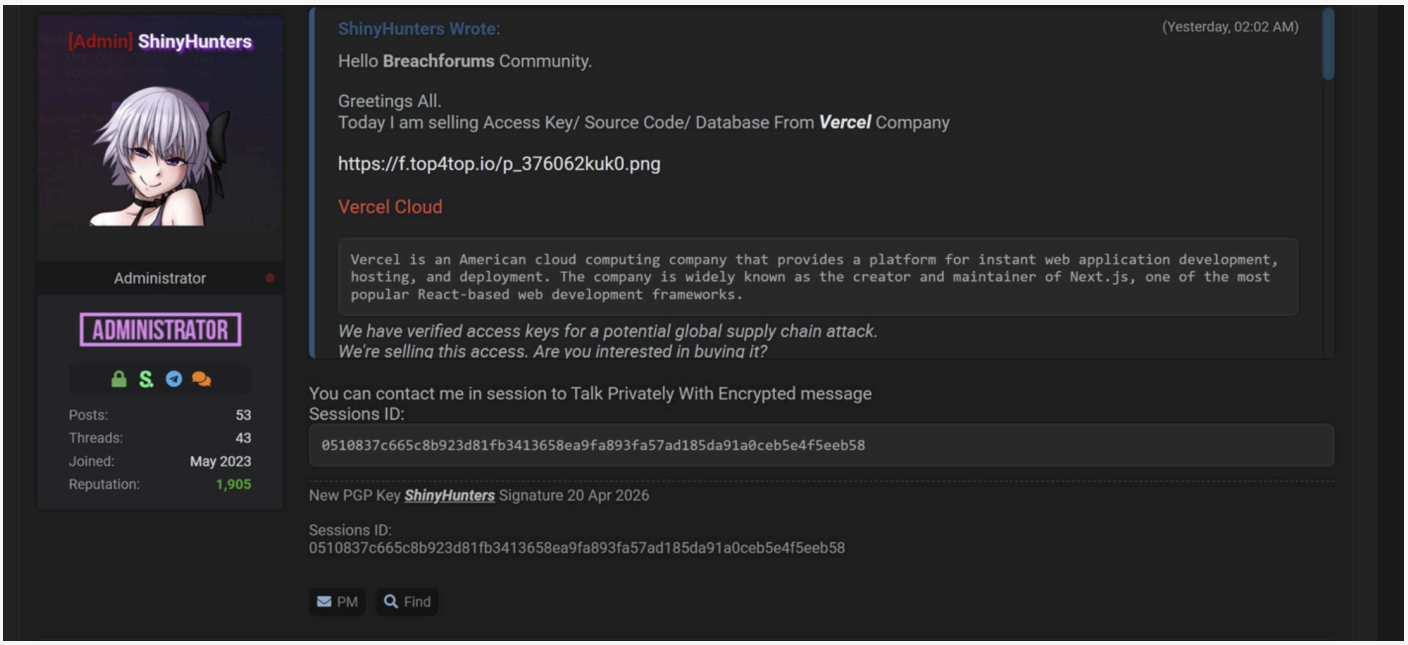
2026 (April listing burst):

- **Dell Technologies (Technology, Jan 2026):** Joint ShinyHunters × LAPSUS$ employee database.
- **Telus (Telecom, Mar 2026):** 700 TB claimed; $65M ransom demand; refused.
- **Cisco (Tech, initial extortion listing March 31, 2026; data publication April 20, 2026 after the April 3 deadline lapsed):** Source code, hard-coded credentials, AWS/Azure keys; listed at $210K.
- **Santander re-listed (Banking, Apr 20, 2026):** 1.6B lines, 28M card numbers; listed at $100K.
- **Verbal (Cloud / DevOps, Apr 20, 2026):** Live access keys, source code, "supply chain attack" framing; price undisclosed.
- **Anthropic "Claude Mythos" (AI, Apr 24, 2026, claimed):** $300K-$500K; analyst-rated low confidence, "probably BS".
- **Compass Inc. (Real-estate tech, Apr 26, 2026):** Full admin access bundled with Okta + Stripe + GitHub + Salesforce; listed at $75K.

The April 2026 burst is worth pausing on. **Five new listings in seven days** between April 20 and 26, 2026. Cisco at $210K. Santander relisted at $100K. Compass at $75K. Vercel access keys at undisclosed price. And Anthropic "Claude Mythos" at $300K-$500K. The technical claims for the Anthropic listing (10-trillion parameters, 20TB model, active zero-day) are inconsistent with public knowledge of AI model architectures, which is why the originating analyst rated the listing low confidence and tagged it "probably BS".

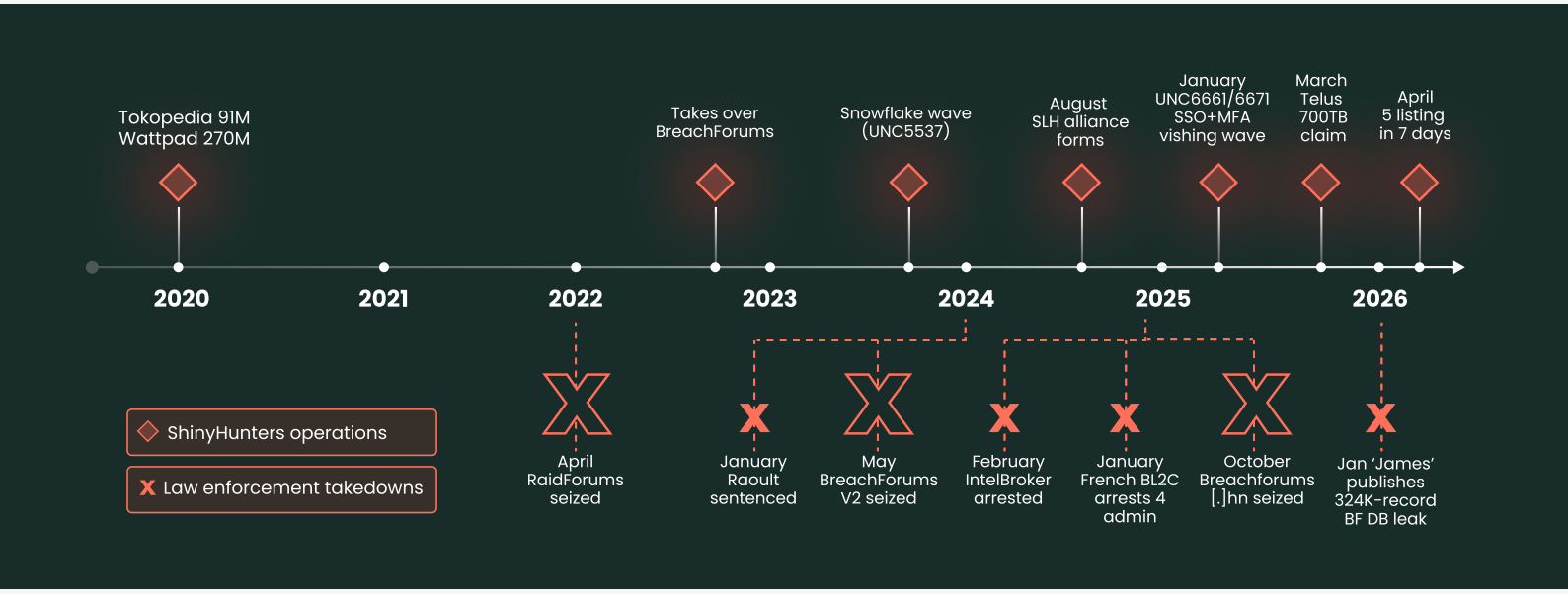


The Vercel and Compass listings broke from ShinyHunters' historical pattern by selling live access, not just dumped data. A qualitative shift from data broker to active access facilitator. A buyer with the Compass package gets identity provider access (Okta), payment processor access (Stripe), and source control (GitHub) in one bundle.



The Cylance/BlackBerry dataset that surfaces in some 2026 corpus reporting is the same 34M-record breach originally listed in **June 2024** by a BreachForums actor under the handle **"Sp1d3r" for $750,000**. BlackBerry assessed the data as old marketing material from 2015–2018 (predating its Cylance acquisition) and denied that current customer systems were compromised. The handle "Sp1d3r" is closely associated with the broader SLH ecosystem but is not interchangeable with the "shinyhunters" forum identity.

Law Enforcement Pressure vs. Brand Resilience



- **Jan 31, 2022:** RaidForums founder Diogo Santos Coelho ("Omnipotent") arrested in U.K.; pending extradition.
- **Apr 12, 2022:** FBI publicly announces RaidForums seizure under Operation TOURNIQUET.
- **Jan 2023:** Sébastien Raoult extradited from Morocco to U.S.
- **Mar 15, 2023:** Conor Fitzpatrick ("pompompurin") arrested in Peekskill, NY.
- **Jan 9, 2024:** Raoult sentenced to 3 years and $5M restitution.
- **May 15, 2024:** FBI seizes BreachForums v2; Baphomet reportedly arrested (unconfirmed by DOJ).
- Feb 2025: Kai West (IntelBroker) arrested in France; U.S. seeks extradition.
- **Apr 28, 2025:** BreachForums offline; admins cite a MyBB zero-day. The cause was contested at the time (DDoS, zero-day, or law-enforcement infiltration) and the takedown was self-initiated rather than seized, so it is not counted as one of the three seizures.
- **Jun 23–25, 2025:** French BL2C arrests four admins (ShinyHunters, Hollow, Noct, Depressed).

- **Aug 11–12, 2025 (honeypot warning, not a formal seizure):** ShinyHunters posts a PGP-signed Telegram message claiming French BL2C, DOJ, and FBI had covertly seized BreachForums' infrastructure, compromised admin accounts (Hollow, ShinyHunters, and a "Founder" account allegedly operated by a federal agent), and modified source code to log all user activity as a surveillance honeypot. The forum goes offline shortly after. ShinyHunters warns associates to treat any BreachForums relaunch as law-enforcement-controlled. This is when the "honeypot" framing originates.
- **Oct 9–10, 2025 (third formal seizure):** FBI and French authorities (BL2C, Paris Prosecutor's Office) formally seize `breachforums[.]hn`, the domain SLH had repurposed as a Salesforce extortion portal, and add a seizure banner with DOJ, FBI, BL2C, and Paris Prosecutor logos. ShinyHunters responds defiantly, stating the seizure "has no impact" on their Salesforce campaign and threatening to release data anyway. This is the third formal forum seizure in ShinyHunters' history (RaidForums 2022, BreachForums v2 2024, breachforums[.]hn 2025).
- **Jan 9, 2026 (publication date):** "James" publishes 323,986 BreachForums user records (the "doomsday leak"). Have I Been Pwned analysis dates the underlying breach to August 2025 (most recent registration in the leaked DB is 2025-08-11).

Counting the admin arrests: Across separate operations, IntelBroker (Feb 2025) + ShinyHunters / Hollow / Noct / Depressed (Jun 2025), five BreachForums-tier admins have been taken into custody. That's distinct from the original ShinyHunters founders (Raoult convicted; Bildstein and El Ahmadi at large in France) and from BreachForums founder Fitzpatrick.

The "James" leak deserves attention as an internal failure, not an external takedown. An actor using the alias "James", described in forum chatter as a disgruntled member or insider rather than a law-enforcement plant, published the BreachForums user database alongside a 4,400-word manifesto. Have I Been Pwned dated the underlying breach to August 2025 based on registration timestamps in the dump; Rescana's post-incident analysis attributed the exposure to an unsecured database backup left accessible during a forum-migration window. The 323,986 records covered a meaningful slice of the active English-speaking cybercrime ecosystem (usernames, IPs, forum activity).

The pattern across this timeline: every takedown is followed within days or weeks by a brand reappearance.

Three forum seizures. Five admins were arrested across three separate operations. The handle keeps posting.

Brand Impersonation and the Attribution Problem

The ShinyHunters name has become valuable enough that it's reused, recycled, and faked. Public reporting through 2025–2026 has linked the name to claimed breaches at ADT, Rockstar Games, Udemy, Zara, Medtronic, Carnival, 7-Eleven, Canada Life, Hallmark, Amtrak, Ameriprise Financial, Wynn Resorts, and the European Commission. Some of these are credible; others are likely opportunistic actors trading on the brand's reputation.

The Vercel listing (April 2026) is a useful case. Vercel's own April 19, 2026 security bulletin says the incident originated through compromise of Context.ai, a third-party AI tool used by a Vercel employee, leading to a Google Workspace takeover and lateral movement into Vercel environments. A ShinyHunters handle then offered access keys, source code, and database content for sale. The link between the intrusion operator and the handle marketing the access remains uncertain.

For defenders, this means attribution to "ShinyHunters" should be treated as attribution to a brand, not to a specific operator. The TTPs and infrastructure are the more reliable signal.

Cato Protections

For Cato Customers:

- **Cato Dynamic Prevention (auto-adaptive threat prevention engine):** Cato announced on March 3, 2026 the first auto-adaptive threat prevention engine running natively in a SASE platform. Dynamic Prevention correlates months of security and networking activity across Cato's inline sensors (IPS, DLP, NGAM) and out-of-band engines, then flags sequences that only look malicious when you see them together (any single step would pass a point-in-time inspection). When the engine confirms a pattern, it adapts and blocks the threat actor's related actions automatically, no SOC ticket, no human triage. The fit with ShinyHunters' UNC6040 chain (vishing → OAuth approval → bulk API exfil) and UNC6395 chain (stolen integration token → bulk exfil) is direct. https://www.catonetworks.com/news/cato-unveils-worlds-first-auto-adaptive-threat-prevention-engine/)
- **Identity-Aware IPS:** Cato IPS detects infostealer C2 patterns associated with Vidar, Redline, Lumma, and Raccoon Stealer. The credential supply chain that feeds ShinyHunters' Snowflake-style attacks.
- **OAuth and SaaS Visibility:** The Cato SASE Cloud Platform provides visibility into anomalous OAuth-connected app authorizations and bulk API activity that characterize UNC6040/UNC6395 campaigns.
- **DLP Policies:** Data Loss Prevention rules flag exfiltration patterns consistent with bulk Salesforce exports and unusual Snowflake `COPY INTO` activity.
- **MDR Threat Hunting:** Cato MDR actively hunts for indicators tied to ShinyHunters infrastructure, including the contact handles and file-hosting URLs listed above.

For Enterprise Defenders:

1. **Phishing-resistant MFA (FIDO2):** Push and SMS MFA do not protect against vishing-induced OAuth approvals or stolen integration tokens. Hardware-backed authenticators are now required for SaaS admin and finance roles, not optional.
2. **OAuth-connected app governance:** Inventory existing connected apps in Salesforce, Google Workspace, and Microsoft 365. Apply allow-listing. Alert on every new connected-app authorization in real time. Revoke unused integrations. Salesloft Drift and Gainsight are specifically named in published advisories. The telemetry that makes this real-time alerting possible lives in Salesforce Event Monitoring (specifically the `LoginHistory` and `ConnectedAppActivity` event types), the Google Workspace admin audit log (token, login, and admin event types), and the Microsoft 365 unified audit log (`UserLoggedIn`, `Add OAuth2PermissionGrant`, `Consent to application`). Pipe those into your SIEM with rules on every new third-party authorization.
3. **Help-desk vishing simulation:** Add "connectivity troubleshooting" scenarios to your social-engineering simulation rotation. The UNC6040 playbook is documented and trainable.
4. **IP-based access restrictions on sensitive APIs:** Bulk API queries from unfamiliar geographies should not be permitted on stolen tokens. Lock high-risk API surfaces to known IP ranges or service-account hosts.
5. **Infostealer credential rotation:** Continuously scan corporate credential leaks across infostealer logs. Rotate any exposed credentials immediately. Contractor and BYOD endpoints are high-risk surfaces. Enforce conditional access.
6. **Dark web monitoring:** Set alerts on `breachforums[.]rs` and the contact addresses listed in the IoC section. Listing activity should trigger proactive incident triage, not reactive disclosure response.

Conclusion

The most useful way to think about ShinyHunters in 2026 isn't as a hacking group. It's as a long-running brand experiment that proved a hypothesis: a federated, persona-driven cybercrime collective can outlast individual member arrests, marketplace seizures, and international coordination, provided the brand is more valuable than any single operator.

The implication for enterprise defenders is direct. Removing ShinyHunters won't happen, and shouldn't be the goal. Removing the conditions that make ShinyHunters' playbook profitable is the goal. That means closing the OAuth-connected-app blind spot, killing infostealer credential reuse with phishing-resistant MFA, and treating help-desk vishing as a first-tier threat instead of a tabletop curiosity.

If your security model assumes the perimeter and MFA together can stop bulk data theft, what's your detection plan when an attacker holds a legitimate OAuth token your help desk approved last Tuesday?



Vitaly Simonovich

Senior Security Researcher

Vitaly Simonovich is a senior security researcher at Cato Networks and member of Cato CTRL. Currently, Vitaly focuses on researching topics related to LLM security, with a particular emphasis on jailbreaks and prompt injections, as well as conducting vulnerability research across a wide range of technologies. In addition, he is actively involved in threat intelligence, analyzing emerging threats and attack trends to strengthen organizational defenses.

Prior to joining Cato in 2023, Vitaly worked at Incapsula and Imperva, where he led teams of security analysts and researchers. With over nine years of experience in cybersecurity, Vitaly specializes in application security, data security, LLM security, vulnerability research, and threat intelligence. An active contributor to the cybersecurity community, Vitaly regularly publishes research blogs, hosts webinars, and presents at conferences. In addition to his professional work, he teaches cybersecurity at local colleges and enjoys solving CTF challenges in his free time to stay sharp and enhance his skills.